Lab: Port scanning with Pen-test Tools

Estimated time needed: **45** minutes

About This Lab

In this lab we will perform a port scan and a website scan using online penetration tools. Pentest-tools.com is an cloud-based penetration testing platform that provides security scanning and vulnerability assessment services.

Objectives

In this hands-on lab, you will:

- Scan a port.
- Scan a website.

Important Notices about This Lab

About Lab Sessions

Lab sessions are not persisted. This means that every time you connect to this lab, a new environment is created for you. Any data or files you saved in a previous session are no longer available. To avoid losing your data, plan to complete these tasks in a single session.

About the Lab Instructions and Solutions

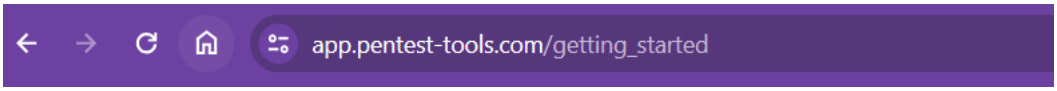
Microsoft Windows operating system features can vary based on the Windows edition. If completing these exercises on your machine, your navigation and solutions may differ from what's presented in this lab.

Exercise 1: Perform a port scan

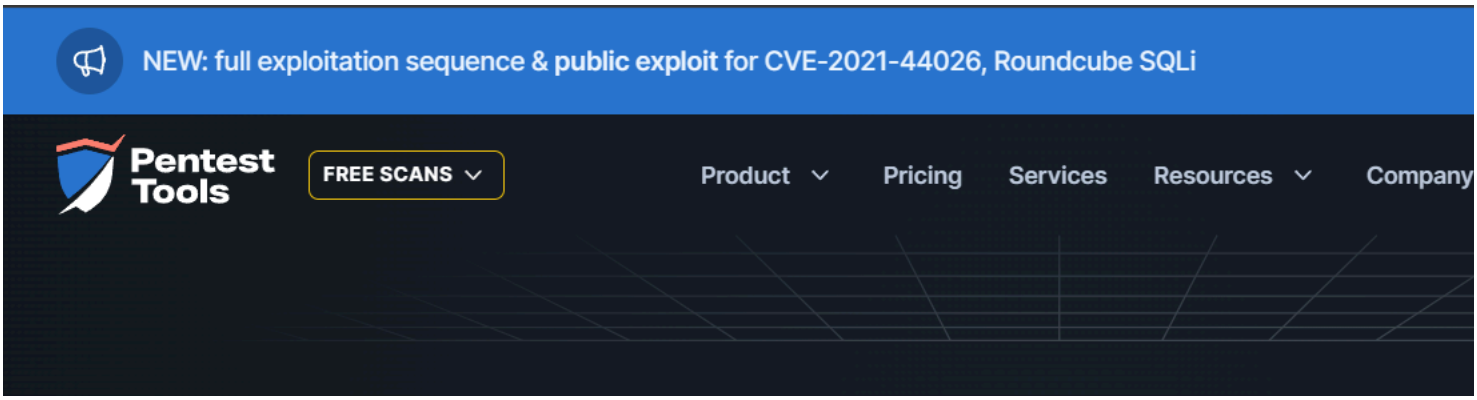
In this exercise we will perform a port scan.

1. Copy and paste the URL into the browser.

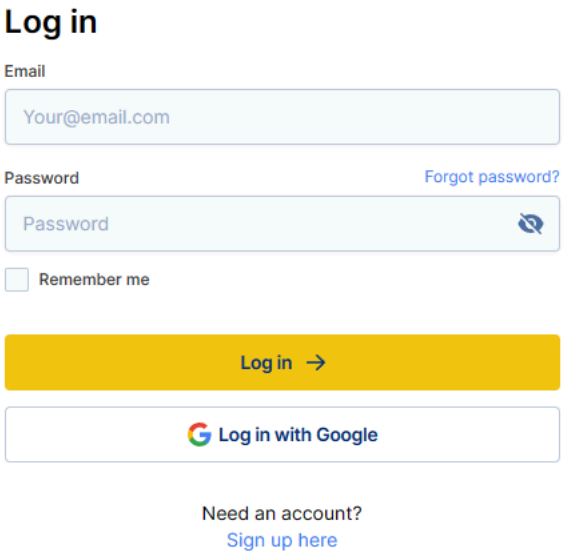
   ```
   pentest-tools.com
   ```



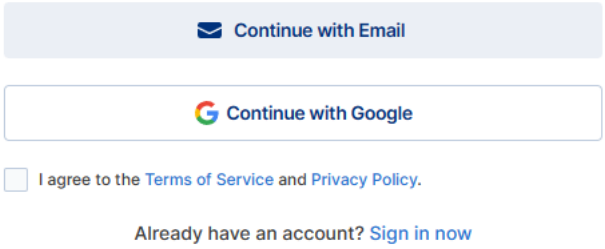
2. Click **`Log in`**.



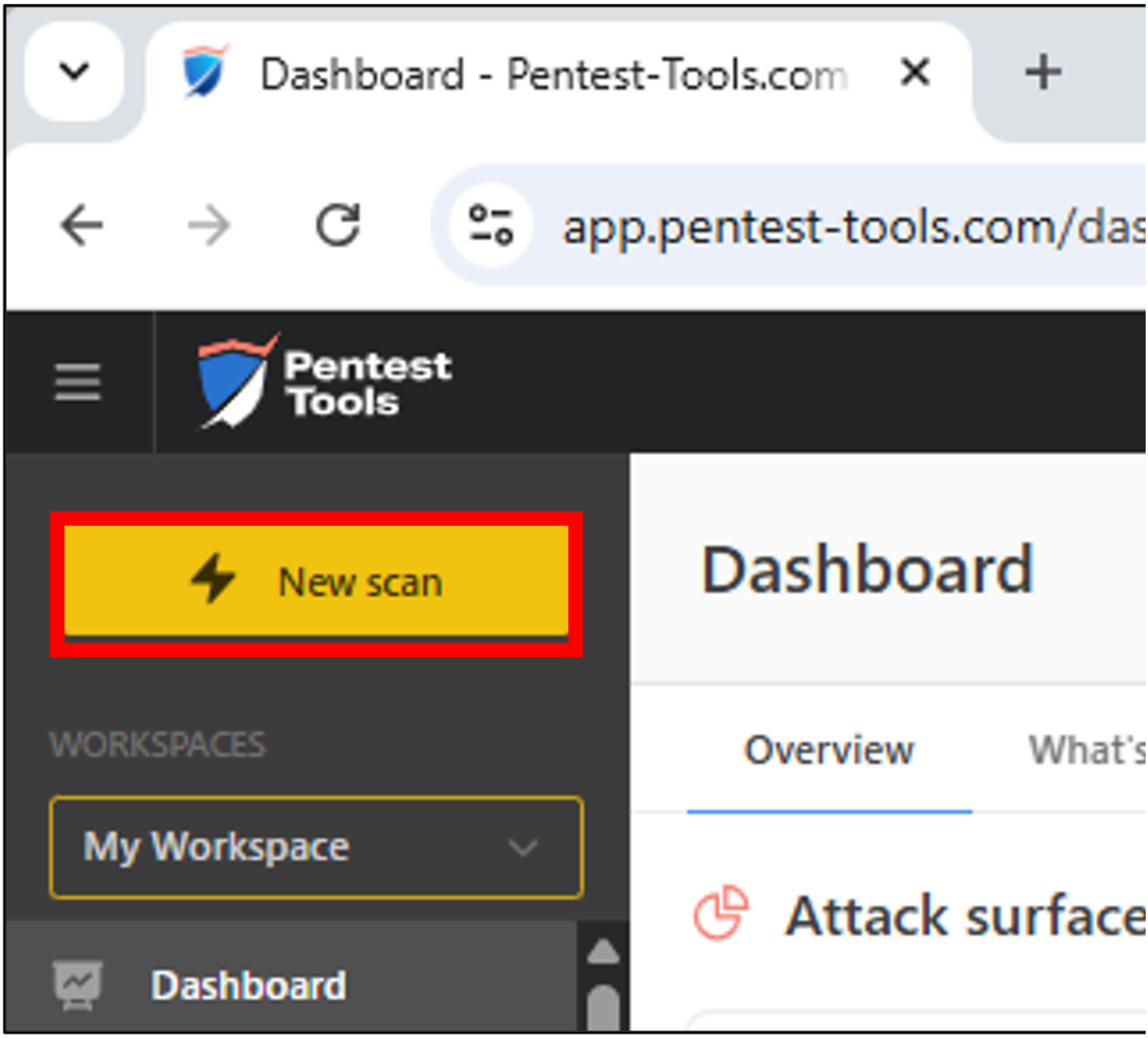
3. Select **`Sign in here`** under **`Need an account?`**



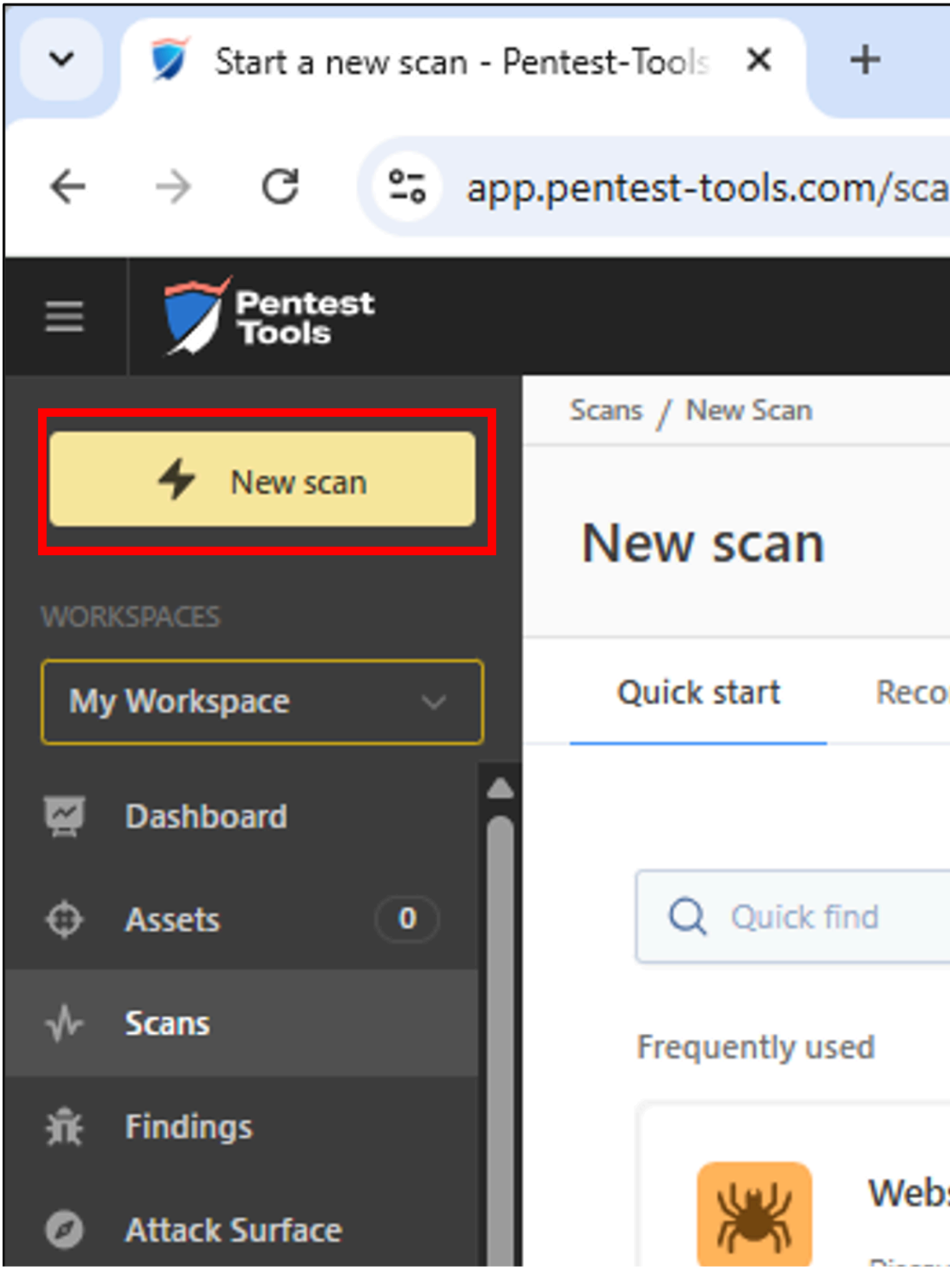
4. Accept the terms and conditions by selecting the **`I agree to the Terms of Service and Privacy Policy`** box and entering your email address.

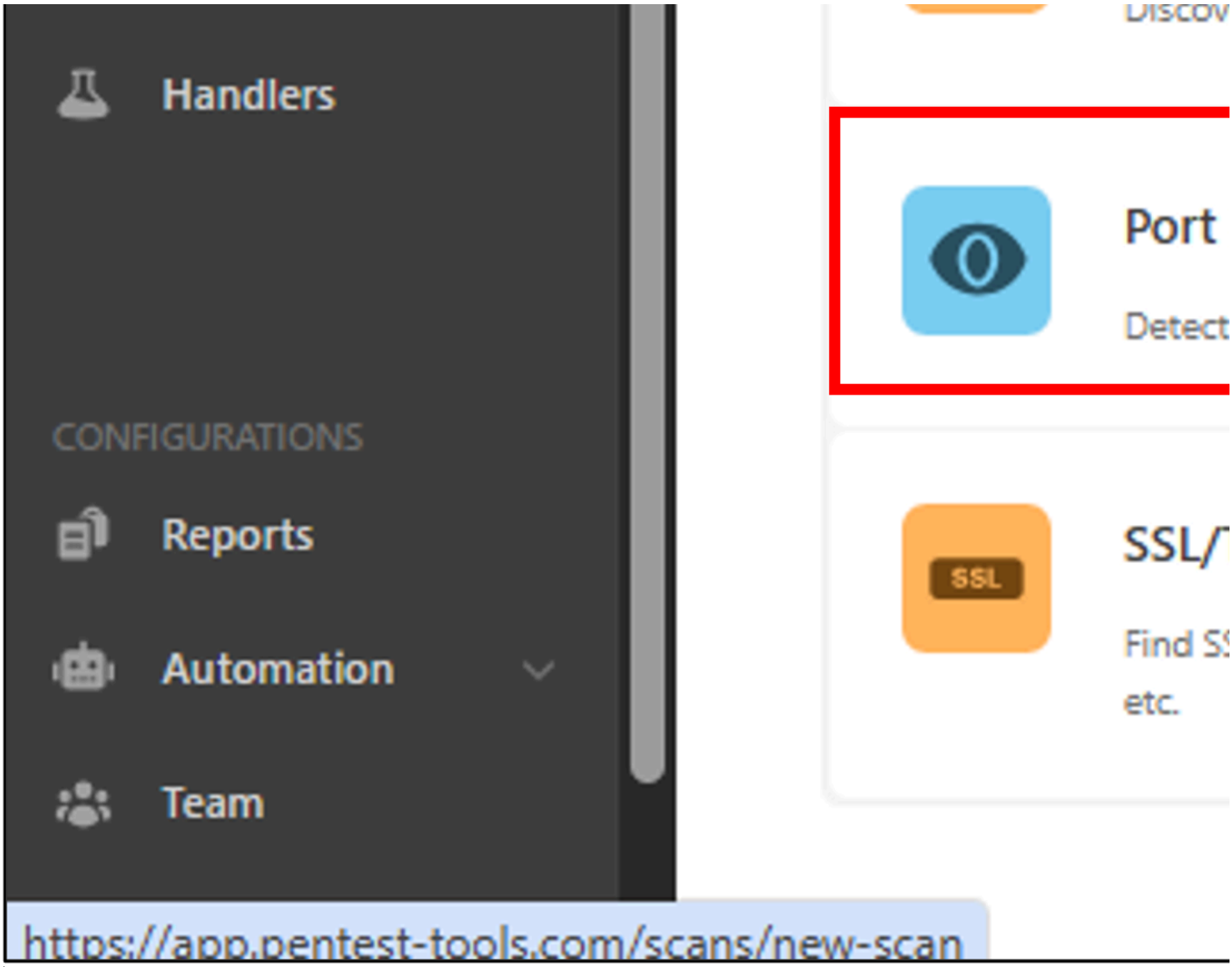


5. Once logged in, click on **`New Scan`** option at the top of the page.



6. Here you see a list of a few dozen tools and scanners used for reconnaissance, web vulnerability testing, network vulnerability scanning, and more active forms of penetration testing. Select **`Port Scanner`**.

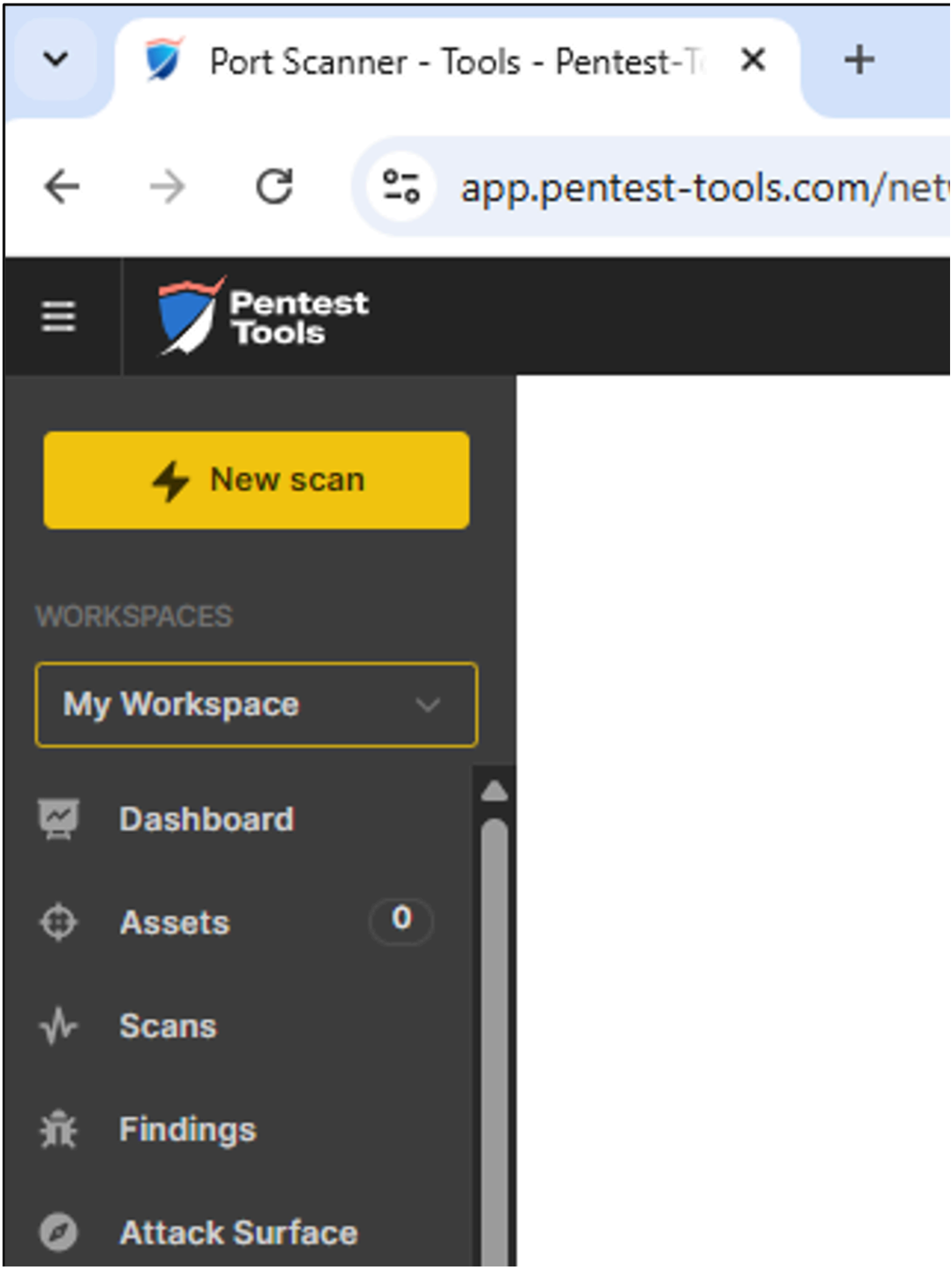

Start a new scan - Pentest-Tools
app.pentest-tools.com/sca
Pentest Tools
New scan
WORKSPACES
My Workspace
Dashboard
Assets 0
Scans
Findings
Attack Surface
Scans / New Scan
New scan
Quick start
Reco
Quick find
Frequently used
Webs

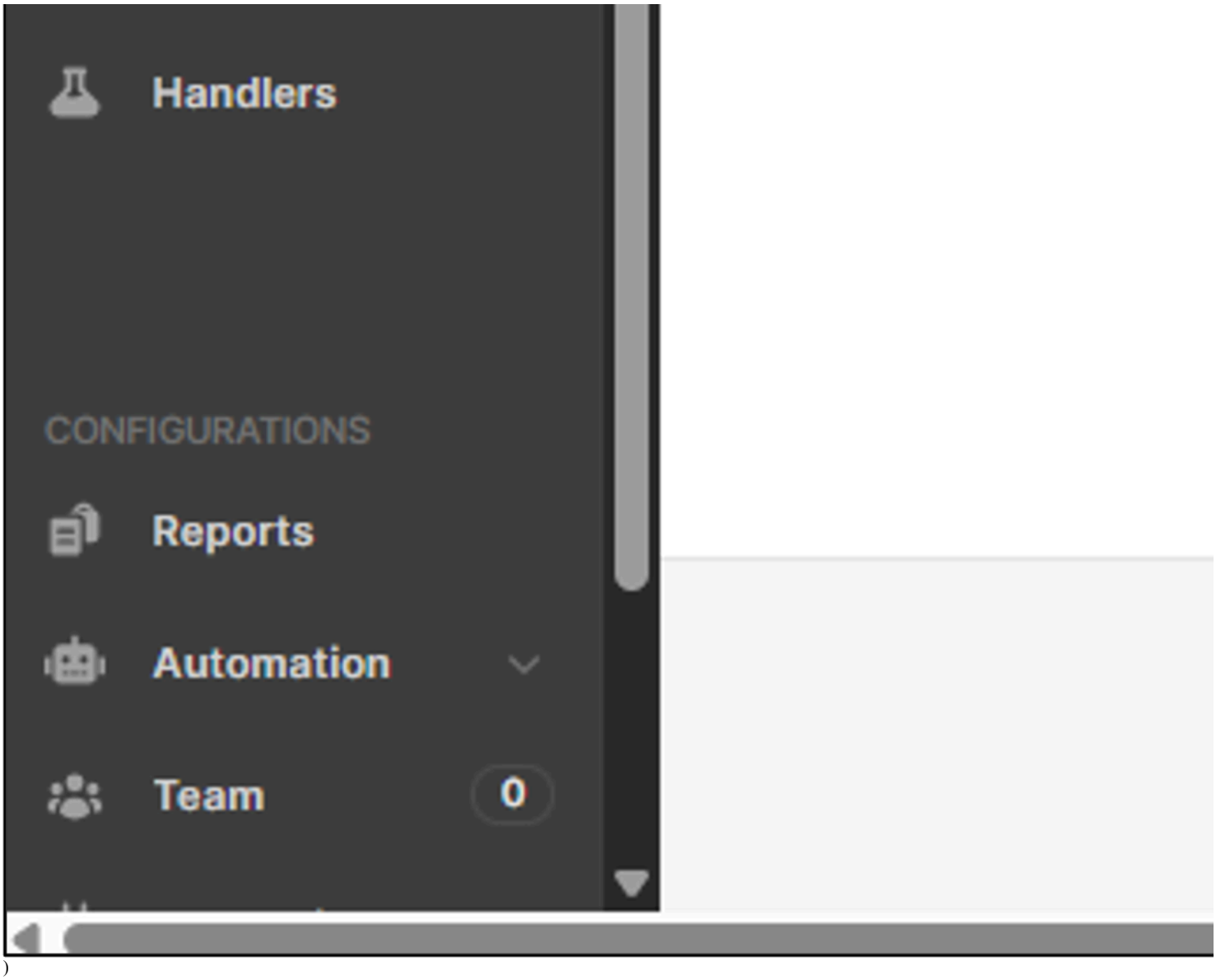


)

7. Copy and paste the following URL into the IP Address text field.

```
scanme.nmap.org
```


Port Scanner - Tools - Pentest-T
app.pentest-tools.com/net
Pentest Tools
New scan
WORKSPACES
My Workspace
Dashboard
Assets
0
Scans
Findings
Attack Surface

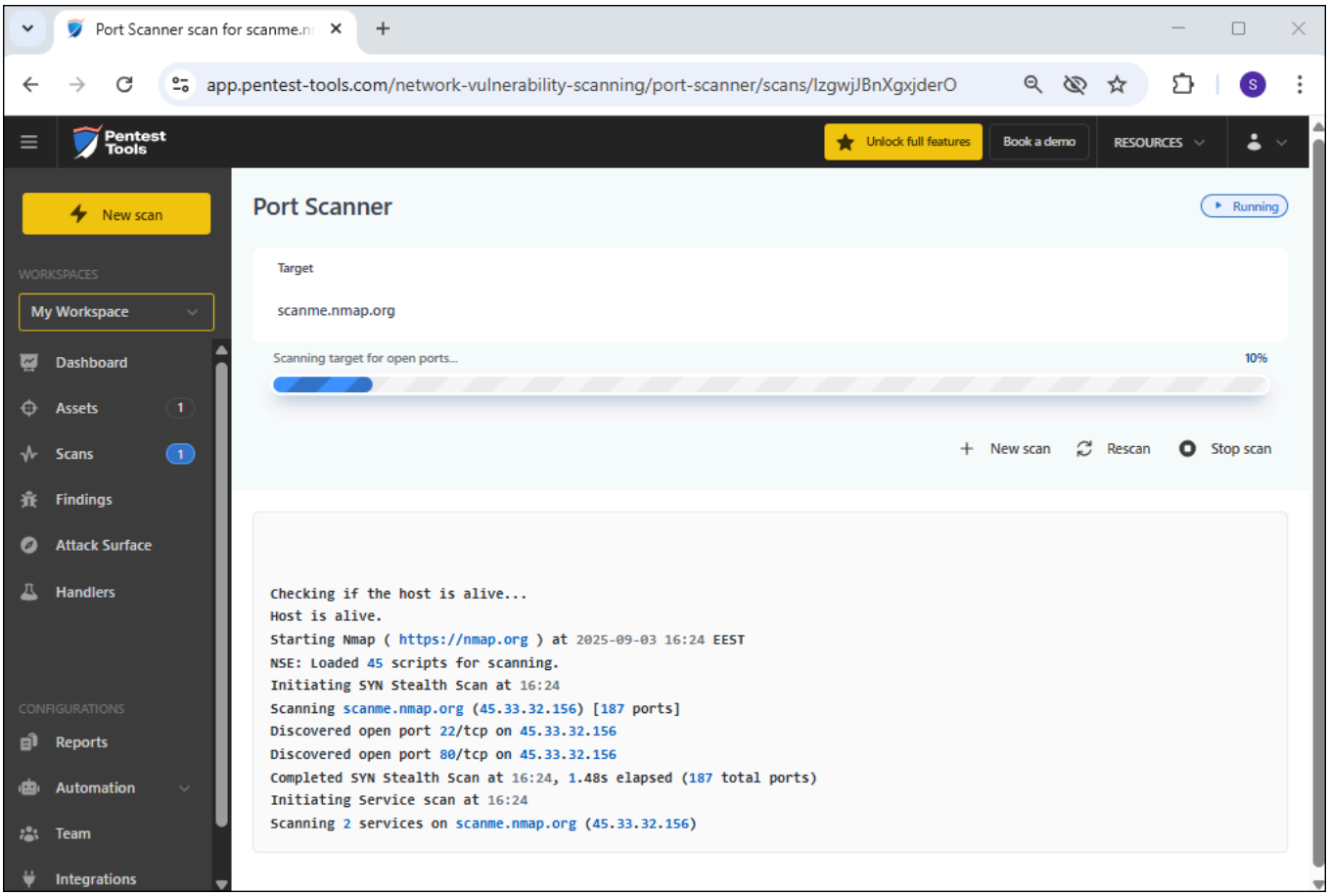


)

8. Verify if the following options are selected and click **`Start Scan`**.

- Scan type: Light
- Protocol type: TCP
- Scan options: ON (Check if host is alive before scanning)
- Custom scan time: OFF
- Notifications: Workspace
- I am authorized to scan this target and I agree to the Terms of Service: (checked)

9. You will see a progress bar indicating that your scan has begun.



10. The result is displayed once the scan is complete. You will see the following:

- **Port Number** and **Protocol**: It indicates the specific protocol (“TCP” or “UDP”) used for communication.
  TCP on -
  Port 80 (HTTP) → for Web browsing
  Port 443 is used (HTTPS) → Secure web browsing
  Port 22 (SSH) → Secure shell login
  Port 25 (SMTP) → Email sending

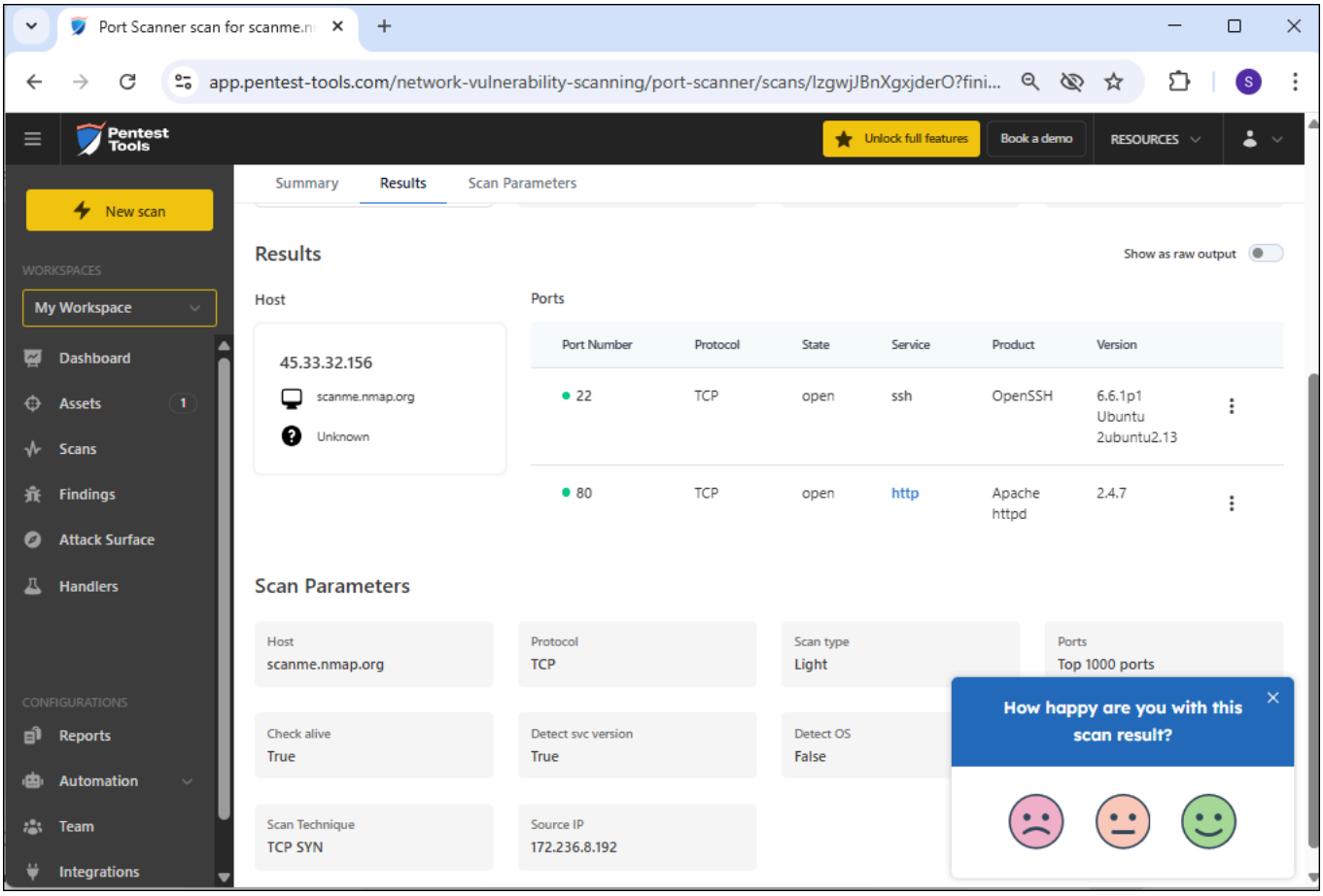
  UDP on -
  Port 53 (DNS) → Domain Name System
  Port 67/68 (DHCP) → Dynamic Host Configuration Protocol
  Port 161 (SNMP) → Network management
  Port 123 (NTP) → Network time sync

- **State**: It refers to the status of a port. The major states are **open**, **closed**, and **filtered**. An open port is where an application actively accepts TCP connections, UDP datagrams, or SCTP associations. A closed port is accessible, but there’s no application listening. A filtered state means a firewall or similar software is protecting the port.

- **Name**: It identifies specific services running on a computer, like HTTP for web servers or SMTP for mail servers.

- **Product**: It refers to the specific software running the service on the port. It could be Apache, AWS, Microsoft, etc., depending on the software installed on the server.

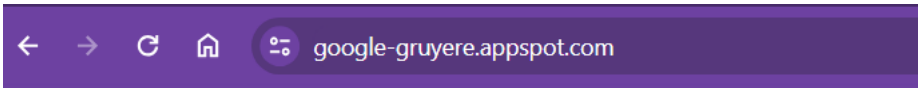
- **Version**: This is the specific version of the software running the service.



Note: scanme.nmap.org is a service provided by the Nmap Security Scanner Project. It is setup for learning and testing. Anyone is authorized to scan this maching with Nmap or other port scanners. Other penetration tests are not permitted. For additional information, visit scanme.nmap.org.

Exercise 2: Perform a Website Scan

1. In a second browser window, visit google-gruyere.appspot.com.



2. Scroll down to the bottom of the page. Carefully read the warning at the bottom of the page and click **`Continue`**.

To get the most out of this lab, you should have some familiarity with how a web application works (e.g., general knowledge of HTML, templates, cookies, AJAX, etc.).

Gruyere



This codelab is built around **Gruyere** /gru͡ːjɛər/ - a small, cheesy web application that allows its users to publish snippets of text and multiple security bugs ranging from cross-site scripting and cross-site request forgery, to information disclosure, denial of service, and guide you through discovering some of these bugs and learning ways to fix them both in Gruyere and in general.

The codelab is organized by types of vulnerabilities. In each section, you'll find a brief description of a vulnerability and a task to find to play the role of a malicious hacker and find and exploit the security bugs. In this codelab, you'll use both black-box hacking and wh find security bugs by experimenting with the application and manipulating input fields and URL parameters, trying to cause applicatio responses to guess server behavior. You do not have access to the source code, although understanding how to view source and being LiveHTTPHeaders for Firefox) is valuable. Using a web proxy like Burp or ZAP may be helpful in creating or modifying requests. In **wh** and can use automated or manual analysis to identify bugs. You can treat Gruyere as if it's open source: you can read through the so Python, so some familiarity with Python can be helpful. However, the security vulnerabilities covered are not Python-specific and you code. You can run a local instance of Gruyere to assist in your hacking: for example, you can create an administrator account on your work and then apply that knowledge to the instance you want to hack. Security researchers use both hacking techniques, often in con

We'll tag each challenge to indicate which techniques are required to solve them:

Challenges that can be solved just by using black box techniques.

Challenges that require that you look at the Gruyere source code.

Challenges that require some specific knowledge of Gruyere that will be given in the first hint.

WARNING: Accessing or attacking a computer system without authorization is illegal in many jurisdictions. While doing this codelab, you are specifically granted authorization to attack the Gru Gruyere in ways other than described in this codelab, nor may you attack App Engine directly or any other Google service. You should use what you learn from the codelab to make your own ap any applications other than your own, and only do that with permission from the appropriate authorities (e.g., your company's security team).

Continue >>

© Google 2017 Terms of Service
The code portions of this codelab are licensed under the Creative Commons Attribution-No Derivative Works 3.0 United States license <https://creativecommons.org/licenses/by-nd/3.0/us>. Brief excerpts of the code may be used f kept intact. Except as otherwise noted the remainder of this codelab is licensed under the Creative Commons Attribution 3.0 United States license <https://creativecommons.org/licenses/by/3.0/us>.

3. Select the URL at the top of the page - https://google-gruyere.appspot.com/start.

Web Application Exploits and Defenses (Part 1)

A Codelab by Bruce Leban, Mugdha Bendre, and Parisa Tabriz

Setup

To access Gruyere, go to `https://google-gruyere.appspot.com/start`. AppEngine will start a new instance of Gruyere for you, assign it a unique id and redirect you to `https://google-gruyere.appspot.com/123/` (where 123 is your unique id). Each instance of Gruyere is "sandboxed" from the other instances so your instance won't be affected by anyone else using Gruyere. need to use your unique id instead of 123 in all the examples. If you want to share your instance of Gruyere with someone else (e.g., to show them a successful attack), just share the full URL them including your unique id.

The Gruyere source code is available online so that you can use it for white-box hacking. You can browse the source code at https://google-gruyere.appspot.com/code/ or download all the files https://google-gruyere.appspot.com/gruyere-code.zip. If want to debug it or actually try fixing the bugs, you can download it and run it locally. You do not need to run Gruyere locally in order t lab.

▶ **Running locally**

Reset Button

As noted above, each instance is sandboxed so it can't consume infinite resources and it can't interfere with anyone else's instance. Notwithstanding that, it is possible to put your Gruyere insta a state where it is completely unusable. If that happens, you can push a magic "reset button" to wipe out all the data in your instance and start from scratch. To do this, visit this URL with your id:

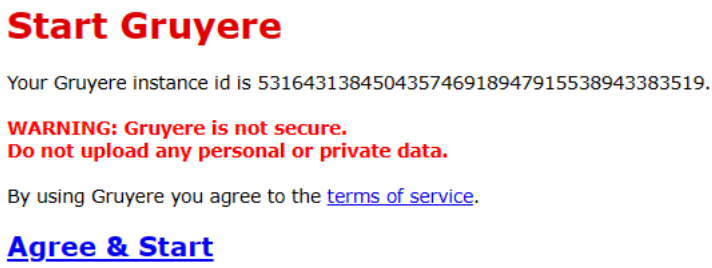
```
https://google-gruyere.appspot.com/resetbutton/123
```

About the Code

Gruyere is small and compact. Here is a quick rundown of the application code:

- `gruyere.py` is the main Gruyere web server
- `data.py` stores the default data in the database. There is an administrator account and two default users.
- `gtl.py` is the Gruyere template language
- `sanitize.py` is the Gruyere module used for sanitizing HTML to protect the application from security holes.
- `resources/...` holds all template files, images, CSS, etc.

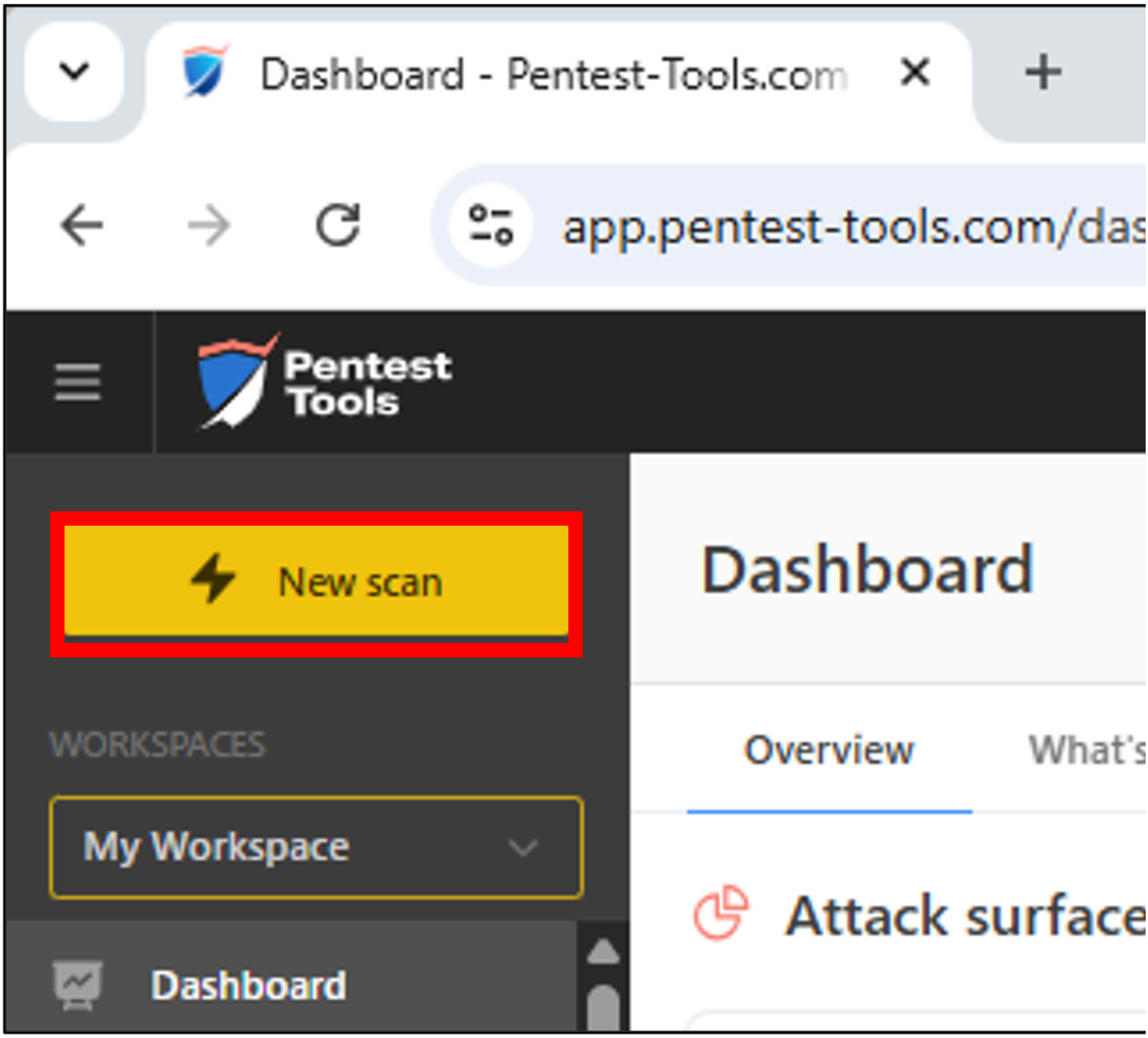
4. Read the page carefully and click **`Agree & Start`**.



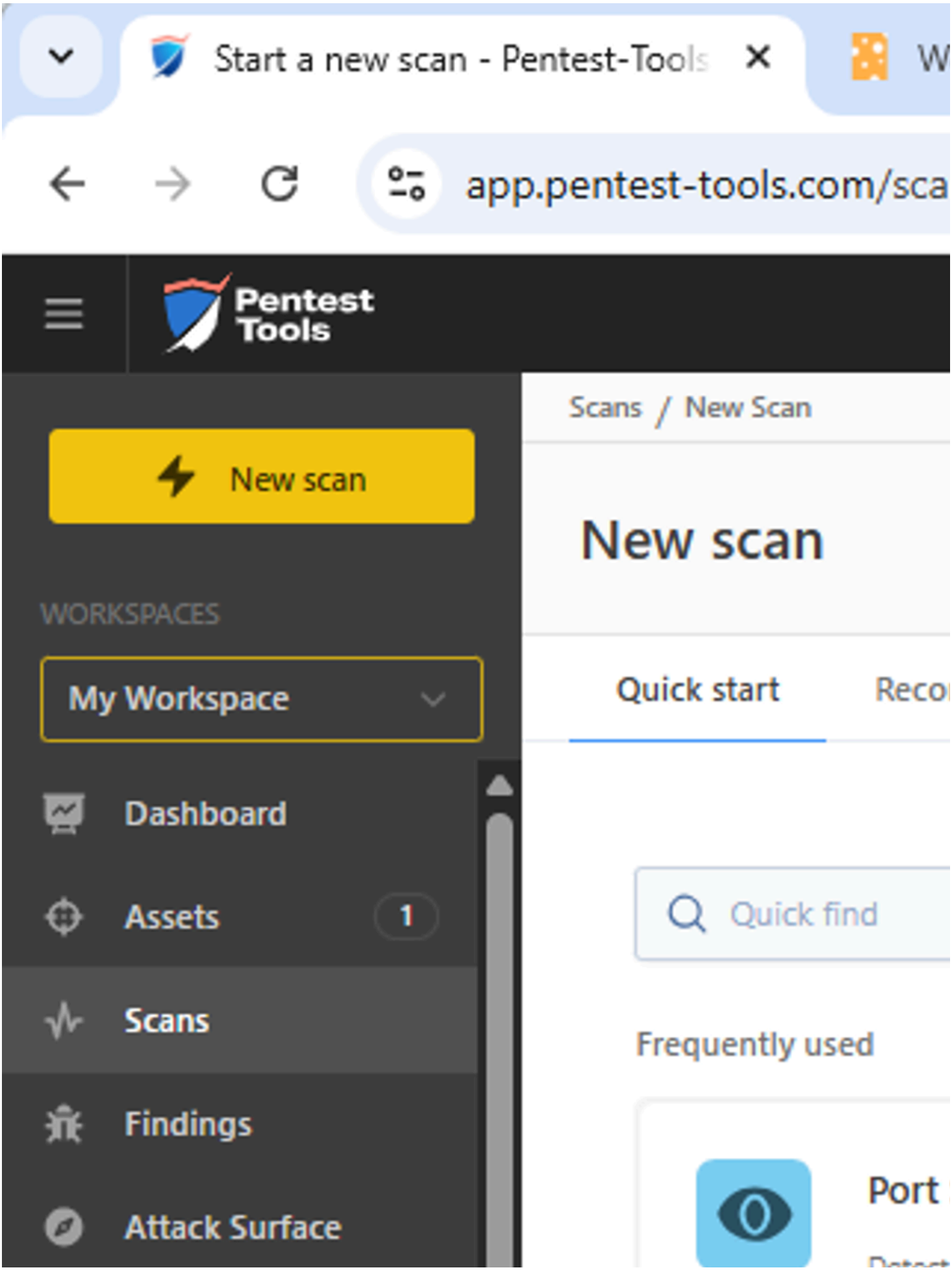
5. Copy and paste the URL from the address bar into your browser (yours will look similar to this screenshot, but the instance numbers will be differ).

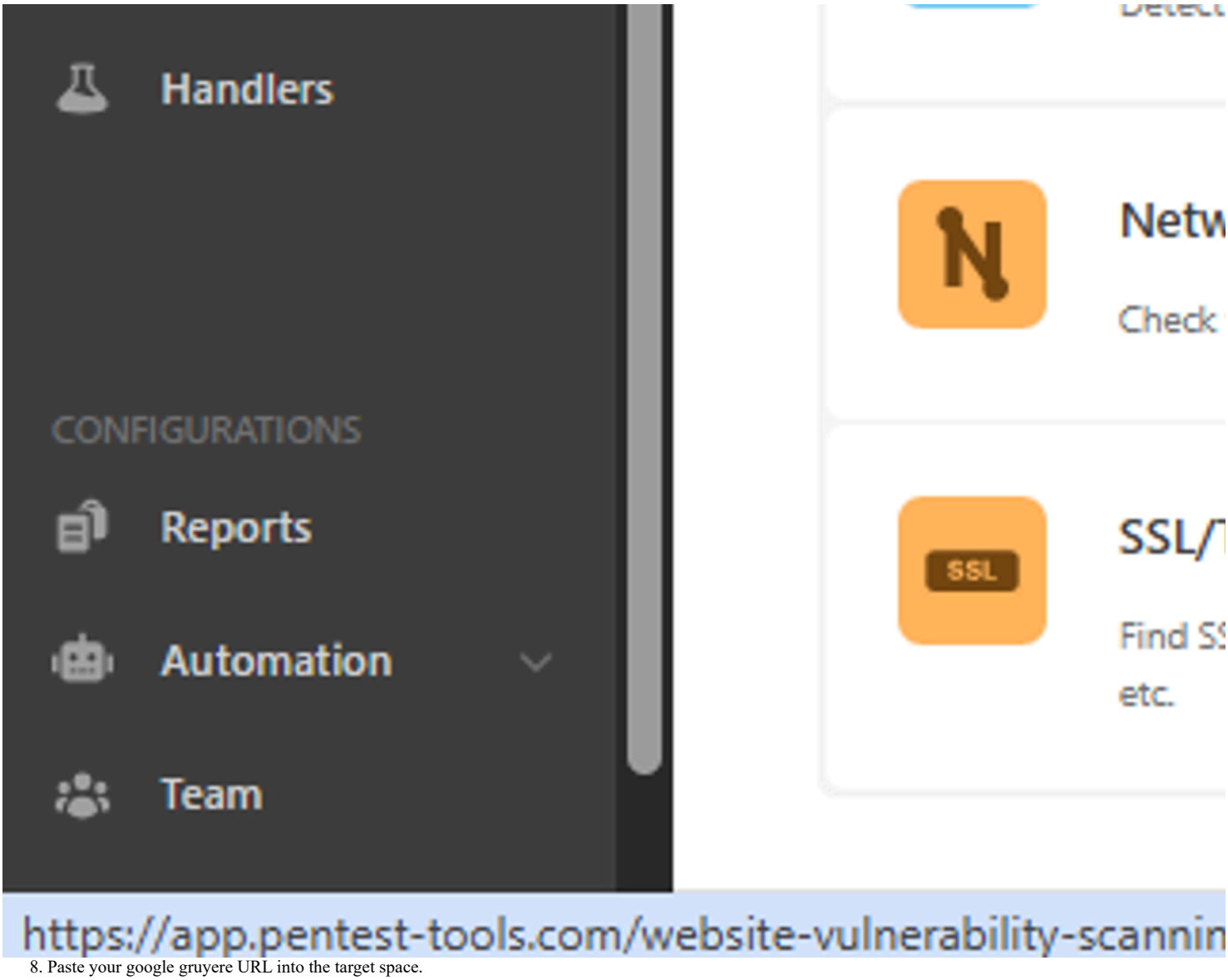


6. Return to the browser tab where you have the pentest-tools.com open. Click on **`New Scan`** option at the top of the page.

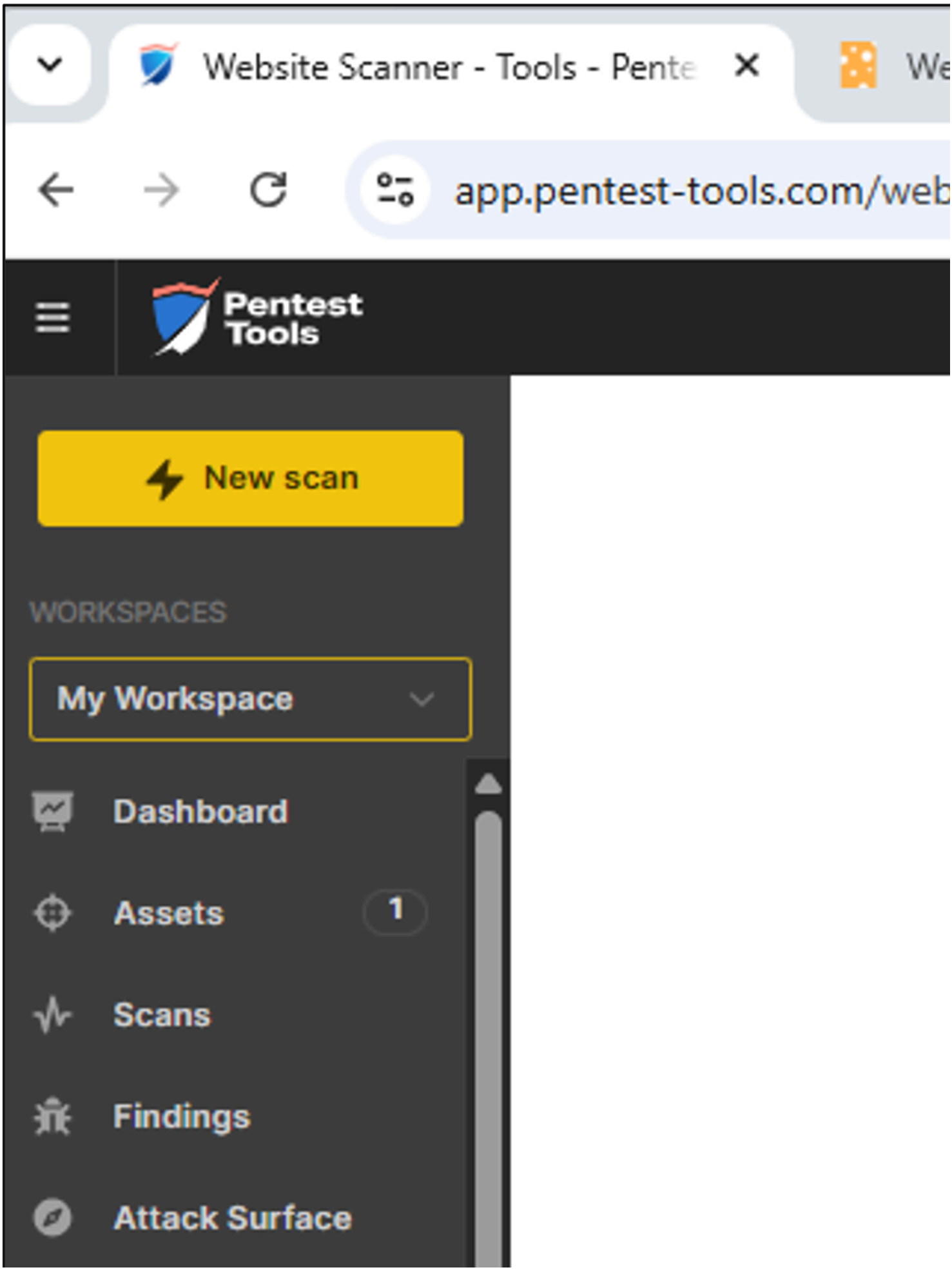


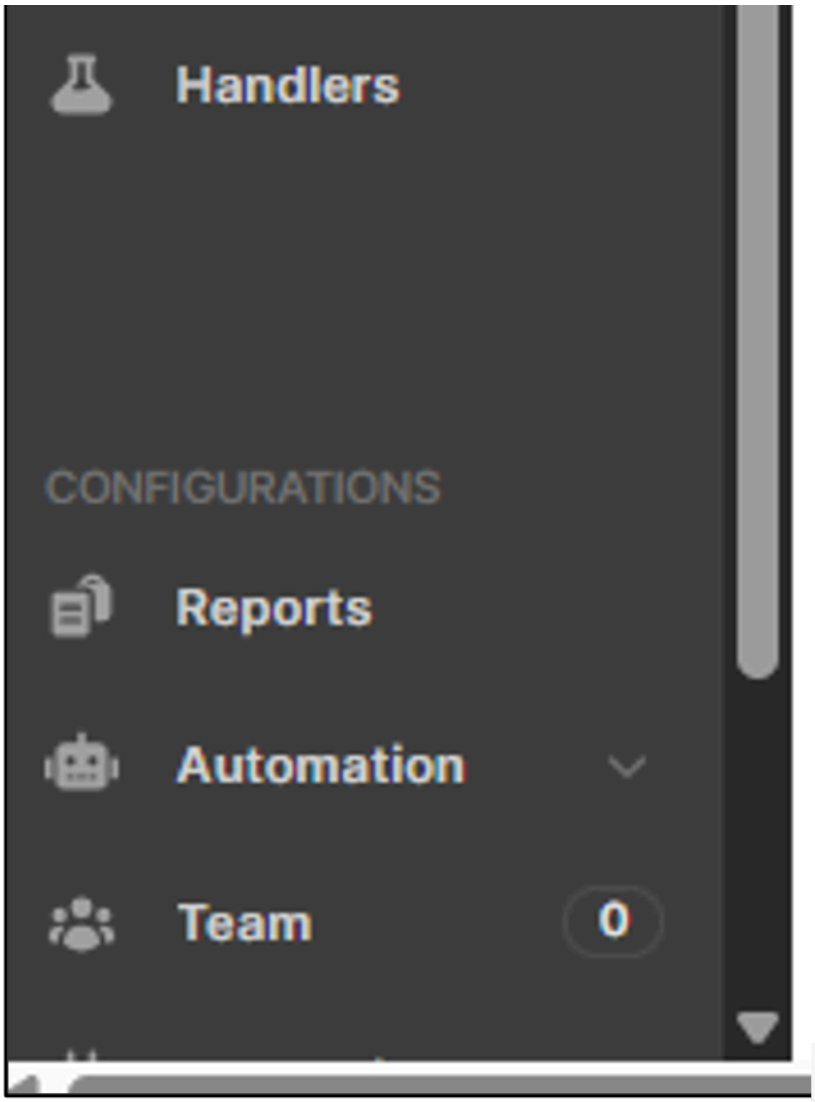
7. Select **`Website Scanner`**.


Start a new scan - Pentest-Tools
app.pentest-tools.com/sca
Pentest Tools
Scans / New Scan
New scan
New scan
WORKSPACES
My Workspace
Quick start
Dashboard
Assets 1
Quick find
Scans
Frequently used
Findings
Attack Surface
Port



8. Paste your google gruyere URL into the target space.

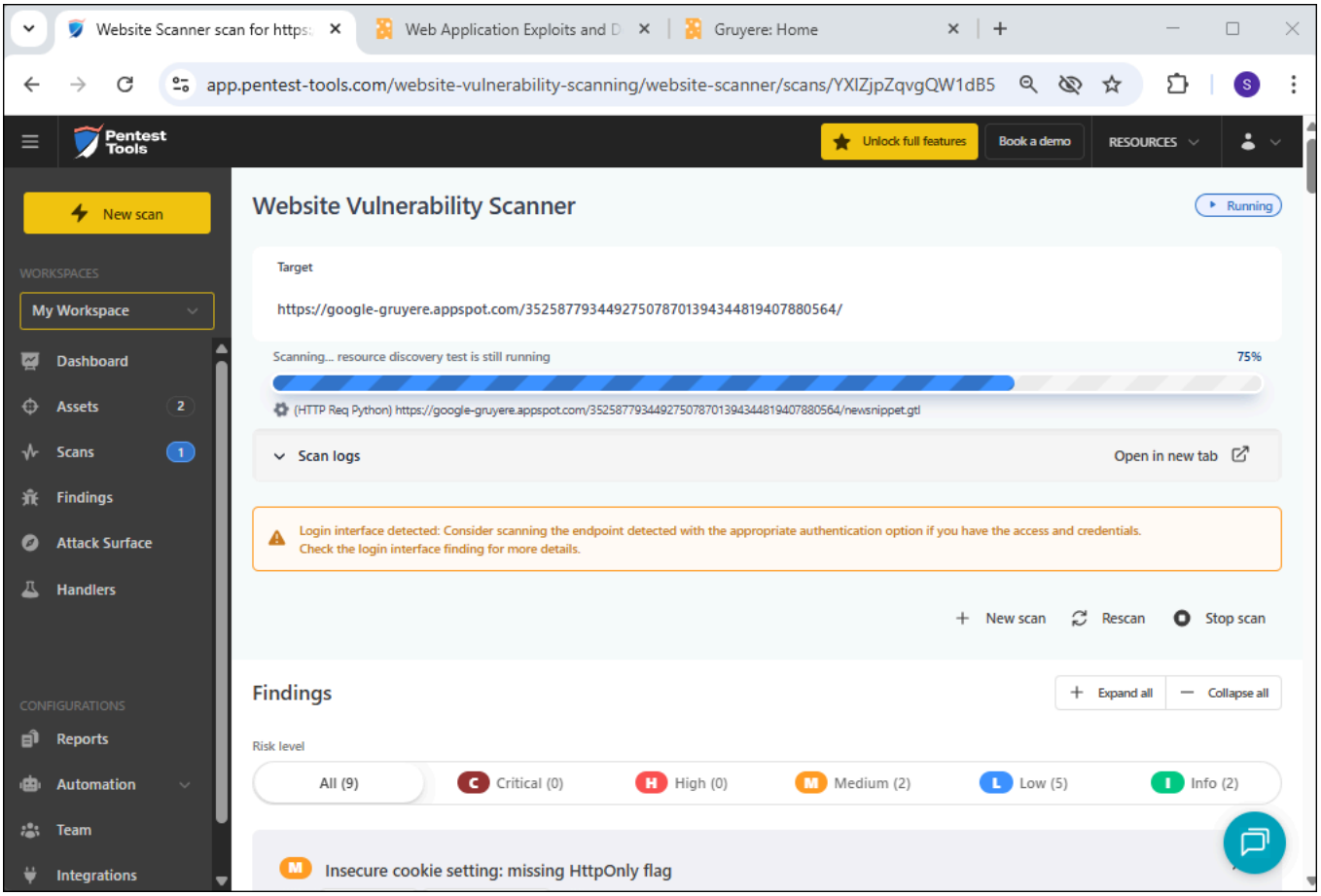

Website Scanner - Tools - Pente
app.pentest-tools.com/web
Pentest Tools
New scan
WORKSPACES
My Workspace
Dashboard
Assets
1
Scans
Findings
Attack Surface



9. Verify if the following options are checked and then click `Start Scan` :

- Scan type: Light scan
- Authentication: Disabled
- Custom scan time: OFF
- Follow redirects: Same-domain only

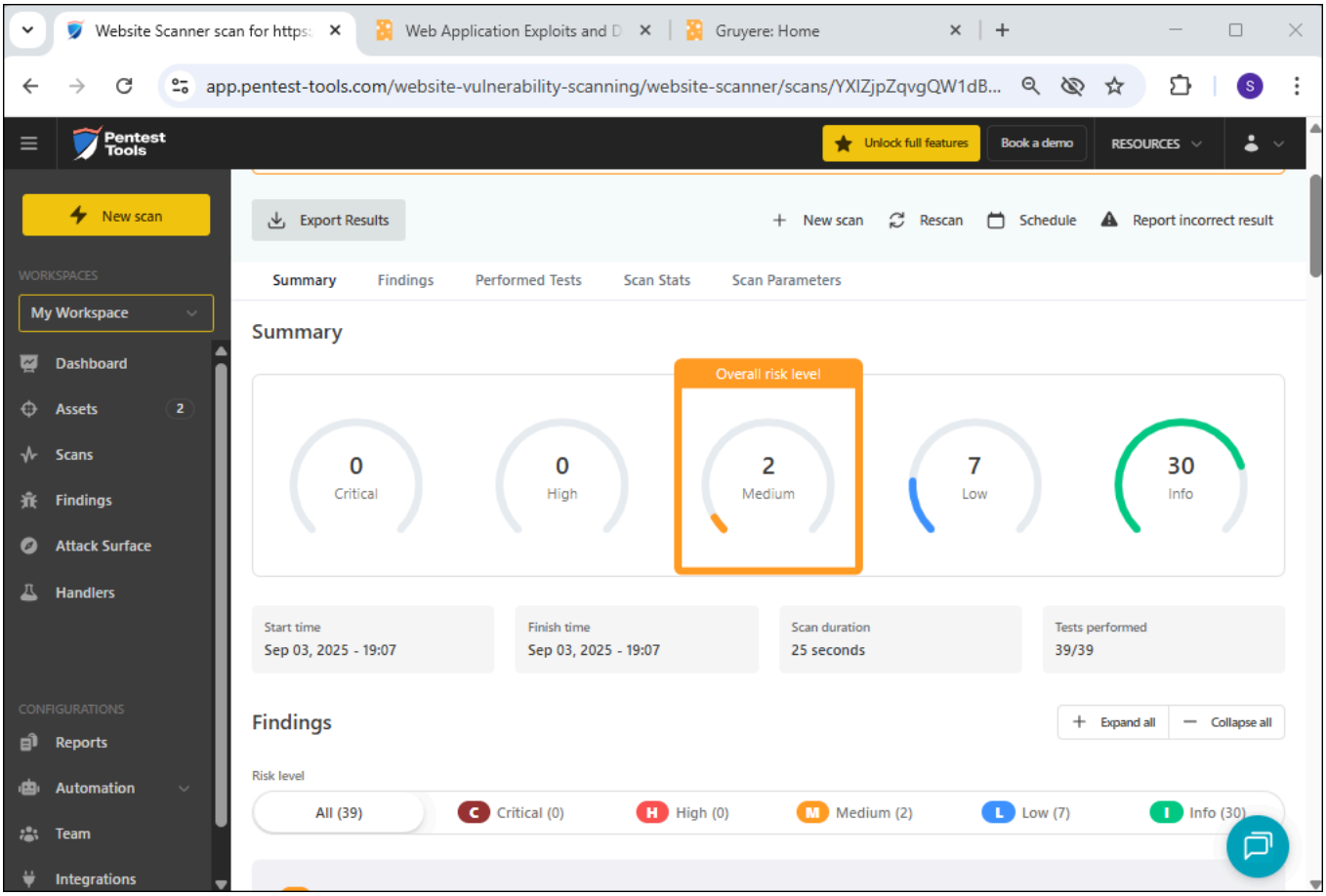
10. You will see a progress bar showing your scanning is running.



11. You will see your website vulnerability scanner results when your scan is complete:

- Summary: Note the high, medium, low, and info risk ratings at the top of the page. Because this is a testing site, the high and medium risks will be low, but if you were scanning a real site, you would want to be very aware of any high or medium risk ratings.
- Findings: Note the findings of the scan. Most likely, you will see some, if not all, of the following:
  – Missing security header: x-frame-options – The x-frame-options header indicates whether the browser should render the resource using a frame or an iframe.
  – Missing security header: content-security-policy – The Content Security Policy (CSP) is an HTTP header that site owners use to set security rules that the browser must follow – such as approved content sources. It's used to help mitigate cross-site scripting and clickjacking attacks.
  – txt file found - Any .txt files stored on the site are listed.

– Security.txt file not found: Although there is no actual risk associated with not having a security.txt file, many cybersecurity experts recommend that every site have one. The file is designed to make it easier for ethical hackers or researchers to reach your organization when they want to report a security vulnerability.



Congratulations! You have completed this lab and are ready for the next topic.

Authors

Dee Dee Collette
Shilpa Giridhar

Skills Network